

Mariaksksk: security audit report

Created on 10 May 2026 @ 19:09

Mariaksksk wants to build trust by giving you insight in how it builds software in a secure manner. The report details how software development at Mariaksksk is being monitored and safeguarded from the developer's computer all the way to the infrastructure used for delivery.

This security report has been generated by Aikido Security based on real-time monitoring of Mariaksksk code and infrastructure.

Aikido benchmark

This percentage gives an indication of your security posture as a company, compared to all other Aikido customers.

Top
20%
of accounts

Section	Score
Score for code repositories	Top 20%
Score for cloud environment	N/A

OWASP Top 10

This section details the OWASP risks for which the organization currently has active measures against.

Code	Title	Taken measures
A01:2021	Broken access control	✓ Application is properly configured ✓ Prevents unauthorized access to resources
A02:2021	Cryptographic failures	✓ Enforces encryption of data at rest ✓ Enforces the use of secure connections
A03:2021	Injection	✓ App scanned for SQL injection attack ✓ Prevents remote code execution ✓ Prevents CSRF attacks ✓ Prevents Cross Site Scripting (XSS) ✓ Prevents command injection
A04:2021	Insecure design	Monitoring, not fully compliant
A05:2021	Security misconfiguration	✓ Application is properly configured
A06:2021	Vulnerable and Outdated Components	✓ No issues have been open longer than their configured SLA
A07:2021	Identification and Authentication Failures	✓ Prevents bypassing authorization controls ✓ Prevents improper certificate validation
A08:2021	Software and Data Integrity Failures	✓ Code repositories use lockfiles to pin dependencies ✓ Takes measures to ensure proper deserialization
A09:2021	Security Logging and Monitoring Failures	✓ Has email notifications set up
A10:2021	Server-Side Request Forgery	✓ App scanned for SSRF attack opportunities



SLA compliance report

The table below shows the configured SLAs and pinpoints instances shows the amount of issues that do currently do not meet these standards.

Issue priority level	SLA	# Issues too late
Critical	5 days	0
High	20 days	0
Medium	60 days	0
Low	100 days	0

ISO 27001:2022 compliance

A brief overview of the ISO 27001 requirements and any measures taken for these.

Title	Taken measures
A.8.2 - Privileged access rights	Monitoring, not fully compliant
A.8.3 - Information access restriction	Monitoring, not fully compliant
A.8.5 - Secure authentication	Monitoring, not fully compliant
A.8.6 - Capacity management	Monitoring, not fully compliant
A.8.7 - Protection against malware	✔ Prevents unwanted write operations to filesystems ✔ Uses Lockfiles to pin code dependencies
A.8.8 - Management of technical vulnerabilities	✔ Does not have any issues outside of their SLA
A.8.12 - Data leakage prevention	✔ Prevents remote code execution ✔ Has measures against SQL injection attacks ✔ Prevents XSS attacks
A.8.13 - Backups	Monitoring, not fully compliant
A.8.15 - Logging	Monitoring, not fully compliant
A.8.18 - Use of privileged utility programs	Monitoring, not fully compliant
A.8.20 - Network security	Monitoring, not fully compliant
A.8.31 - Separation of development, test and production environments	Monitoring, not fully compliant
A.8.24 - Use of cryptography	✔ Uses secure cookies ✔ Uses up-to-date cryptographic libraries
A.8.9 - Configuration management	✔ Uses Lockfiles to pin code dependencies



A.8.16 - Monitoring activities	 Receives security alerts in real time
A.8.25 - Secure development lifecycle	 Has connected a code repository
A.8.28 - Secure coding	 Does not have any issues outside of their SLA
A.8.32 - Change management	Monitoring, not fully compliant
A.5.15 - Access control	Monitoring, not fully compliant
A.5.16 - Identity management	Monitoring, not fully compliant
A.5.28 - Collection of evidence	Monitoring, not fully compliant
A.5.33 - Protection of records	Monitoring, not fully compliant

Esquema Nacional de Seguridad (ENS) compliance

A brief overview of the ENS requirements and any measures taken for these.

Título	Medidas Tomadas
[op.pl.4] Planificación\Dimensionamiento - gestión de la capacidad	No se han tomado medidas activas
[op.acc.1] Control de acceso\Identificación	No se han tomado medidas activas
[op.acc.2] Control de acceso\Requisitos de acceso a la información	No se han tomado medidas activas
[op.acc.2] Control de acceso\Requisitos de acceso - programas utilitarios privilegiados.	No se han tomado medidas activas
[op.acc.2] Control de acceso\Requisitos de acceso - acceso a la información - mínimo privilegio	No se han tomado medidas activas
[op.acc.4] Control de acceso\Proceso de gestión de derechos de acceso privilegiados	No se han tomado medidas activas
[op.acc.6] Control de acceso\Mecanismo de autenticación (usuarios de la organización)	No se han tomado medidas activas
[op.exp.3] Explotación\Gestión de la configuración	✔ Usa Lockfiles para fijar dependencias de código
[op.exp.4] Explotación\Mantenimiento y actualizaciones de seguridad - Gestión de vulnerabilidades técnicas	✔ no_issues_outside_of_sla
[op.exp.5] Explotación\Gestión de cambios en sistemas y aplicaciones	No se han tomado medidas activas



[op.exp.6] Explotación\Protección frente a código dañino	✓ Prevención de operaciones de escritura no deseadas en sistemas de archivos ✓ Usa Lockfiles para fijar dependencias de código
[op.exp.8] Explotación\Registro de la actividad y eventos de seguridad	No se han tomado medidas activas
[op.exp.8] Explotación\Registro de la actividad y logs de actividad	No se han tomado medidas activas
[op.exp.9] Explotación\Registro de la gestión de incidencias - recolección de evidencia	No se han tomado medidas activas
[op.mon.3] Monitorización del sistema\Vigilancia - monitoreo de actividades y eventos de seguridad	✓ Recibe alertas de seguridad en tiempo real
[mp.com.1] Protección de las comunicaciones\Perímetro seguro - medidas de seguridad para proteger la red	No se han tomado medidas activas
[mp.si.2] Protección de los soportes de información\Criptografía	✓ Uso seguro de cookies ✓ Uso de librerías criptográficas actualizadas
[mp.sw.1] Protección de las aplicaciones informáticas\Desarrollo de aplicaciones - separación de los entornos	No se han tomado medidas activas
[mp.sw.1] Protección de las aplicaciones informáticas\Ciclo de vida de desarrollo seguro de aplicaciones	✓ Ha conectado un repositorio de código
[mp.info.6] Protección de la información\Copias de seguridad	No se han tomado medidas activas
[mp.s.1] Protección de los servicios\correo electrónico - medidas prevenir la fuga de datos	✓ Prevención de ejecución remota de código ✓ Se tienen medidas para proteger contra ataques de inyección de SQL ✓ Prevención contra ataques de Cross-Site Scripting (XSS)



SOC2 compliance

A brief overview of the SOC2 requirements and any measures taken for these.

Title	Taken measures
CC3.3: Consider the potential for fraud	Monitoring, not fully compliant
CC3.2: Estimate Significance of Risks Identified	✓ Does not have any severe surface monitoring issues ✓ Does not have any severe open source dependency issues ✓ Configured monitoring for container images
CC5.2: The entity selects and develops general control activities over technology to support the achievement of objectives	✓ Does not have any severe infrastructure as code issues
CC6.1: Restricts logical access	✓ Has measures against SQL injection attacks ✓ Is protected against SSRF attacks ✓ Is protected against command injections attacks ✓ Prevents XSS attacks
CC6.1: Consider network segmentation	Monitoring, not fully compliant
CC6.1: Restrict access to information assets	Monitoring, not fully compliant
CC6.1: Manages credentials for infrastructure and software	Monitoring, not fully compliant
CC6.1: Use encryption to protect data	✓ Enforces encryption of data in transit ✓ Uses up to date cryptography libraries
CC6.6: Restrict Access	Monitoring, not fully compliant
CC6.6: Require additional authentication or credentials	Monitoring, not fully compliant



CC6.6: Implement boundary protection system	Monitoring, not fully compliant
CC6.7: Use encryption technologies or secure communication channels to protect data	✓ Uses up to date cryptography libraries
CC6.8: Restrict application and software installation	✓ Protects unauthorized runtime access ✓ Prevents container orchestration takeover
CC6.8: Detect unauthorized changes to software and configuration parameters	Monitoring, not fully compliant
CC6.8 Use anti-virus and anti-malware software	✓ Aikido Malware Scanner is enabled
CC7.1: Monitor infrastructure and software	✓ Configured SLAs to resolve issues ✓ Connected code repositories
CC7.1: Implement change detection mechanism	Monitoring, not fully compliant
CC7.1: Detect unknown or unauthorized components	✓ Does not have risky licenses
CC7.1: Conduct vulnerability scans	✓ Uses Lockfiles to pin code dependencies ✓ Does not have any issues outside of their SLA ✓ Connected code repositories
CC7.1: Implement filters to analyze anomalies	✓ Connected code repositories
CC7.1: Restores the affected environments	✓ Has no critical open source dependency issues
CC8.1: Protect confidential information	Monitoring, not fully compliant
CC8.1: Track system changes	Monitoring, not fully compliant

CC10.3: Tests integrity and completeness of backup data

Monitoring, not fully compliant



CIS v8.1 Controls compliance

A brief overview of the CIS controls and any measures taken for these.

Title	Taken measures
2.2 Ensure Authorized Software is Currently Supported	Monitoring, not fully compliant
3.3 Configure Data Access Control Lists	Monitoring, not fully compliant
3.4 Enforce Data Retention	✔ Enabled security logging for cloud instances
3.10 Encrypt Sensitive Data in Transit	✔ Enforces encryption of data in transit
3.11 Encrypt Sensitive Data at Rest	✔ Encrypts data at rest
3.14 Log Sensitive Data Access	✔ Enabled security logging for cloud instances
4.4 Implement and Manage a Firewall on Servers	✔ Prevents unauthorized public access to file storage ✔ Prevents unauthorized public access to database
4.6 Securely Manage Enterprise Assets and Software	✔ Enforces latest TLS version ✔ Enforces encryption of data in transit
4.9 Configure Trusted DNS Servers on Enterprise Assets	✔ Uses DNSSEC extensions
5.4 Restrict Administrator Privileges to Dedicated Administrator Accounts	Monitoring, not fully compliant
6.5 Require MFA for Administrative Access	Monitoring, not fully compliant
6.4 Require MFA for Remote Network Access	Monitoring, not fully compliant
7.1 Establish and Maintain a Vulnerability Management Process	✔ Configured SLAs to resolve issues



8.2 Collect Audit Logs	✔ Enabled security logging for cloud instances
10.1 Deploy and Maintain Anti-Malware Software	✔ Uses Lockfiles to pin code dependencies ✔ No malware issues ✔ Prevents unwanted write operations to filesystems
11.2 Perform Automated Backups	✔ Has backups for stateful cloud resources
12.3 Securely Manage Network Infrastructure	✔ Prevents unauthorized public access to networks and instances ✔ Prevents unauthorized public access to database
12.6 Use of Secure Network Management and Communication Protocols	✔ Prevents unauthorized public access to networks and instances ✔ Enforces encryption of data in transit ✔ Uses secure communications protocols
13.6 Collect Network Traffic Flow Logs	✔ Enabled security logging for cloud instances
16.2 Establish and Maintain a Process to Accept and Address Software Vulnerabilities	Monitoring, not fully compliant
16.5 Use Up-to-Date and Trusted Third-Party Software Components	✔ No risky licenses in 3rd party dependencies ✔ Configured SLAs to resolve issues ✔ no_issues_outside_of_sla
16.8 Separate Production and Non-Production Systems	Monitoring, not fully compliant
16.12 Implement Code-Level Security Checks	Monitoring, not fully compliant

DORA compliance

A brief overview of the DORA Compliance Checklist and any measures taken for these.

Title	Taken measures
Article 7, ICT Risk Management: Systems, Protocols, and Tools	Monitoring, not fully compliant
Article 8, ICT Risk Management: Identification	 Has connected code repositories
Article 9, ICT Risk Management: Protection and prevention	 Use of Cryptography: Enforces SSL  Use of Cryptography: Secure Cookies
Article 10, ICT Risk Management: Detection	Monitoring, not fully compliant
Article 11, ICT Risk Management: Response and Recovery	 Does not have any issues outside of their SLA  Has email notifications set up
Article 12, ICT Risk Management: Backup	Monitoring, not fully compliant
Article 15, Harmonization With Other Regulations	Monitoring, not fully compliant
Article 17, Incident Management Process	 Does not have any issues outside of their SLA  Has email notifications set up
Article 18, Classification of Incidents and Cyber Threats	 Configured monitoring for container images



Scan history report

This section details all company assets that are being monitored and how often scans are performed.

Kind	Frequency	Last occurence
Open-source dependencies: 63 dart packages monitored	Daily	2026-05-10
OSS licenses: 63 monitored for compliance	Weekly	2026-05-10
Static app security testing: 1 repository monitored	Daily	2026-05-10
Infrastructure as code: monitored for misconfigurations	Daily	2026-05-10
Exposed secrets: history of 1 repository scanned	Daily	2026-05-10

Issue insights over the past 3 months

The table below gives an overview of new findings in a 3 month rolling window. A triaged finding is one that has been either been solved, ignored after analysis or planned in a task management system for resolution.

Issue kind	New	False positives	Handled
Open-source Dependencies	0	0	0
Container Images	0	0	0
Cloud Configurations	0	0	0
Virtual Machines	0	0	0
Secrets in source code history	3	0	0
DAST/Surface Monitoring	0	0	0
SAST/Static App Security Testing	0	0	0
Infrastructure As Code	0	0	0
Mobile	9	0	0
End-of-life Runtimes	0	0	0
Access Controls	0	0	0
Licenses	0	0	0
Malware Issues	0	0	0
AI Pentest Issues	0	0	0

